Information Security

Principles of Information Security, Michael E., Whitman & Mattord, H. J., Cengage Learning, 2017.

Roadmap

- Security?
- Security types
- Possible Security violation
- Threat consequences
- Key objectives of computer security
- OSI security architecture
- Security policy
- Security terminology
- IS component

What is Security?

- "The quality or state of being secure—to be free from danger"
- A successful organization should have multiple layers of security in place:
  - Physical security
  - Personal security
  - Operations security
  - Communications security
  - Network security
  - Information security

What is Information security?

- The protection of information and its critical elements, including systems and hardware that use, store, and transmit that information
- Necessary tools: policy, awareness, training, education, technology

Definitions

- **Computer Security** - generic name for the collection of tools designed to protect data and to thwart hackers
- **Network Security** - measures to protect data during their transmission over a network
- **Internet Security** - measures to protect data during their transmission over a collection of interconnected networks

Information security:

- a “well-informed sense of assurance that the information risks and controls are in balance.” — Jim Anderson, (2002)

Information Security

- The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability, and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications).

Network and Internet security

- The field of **network and Internet security** consists of measures to deter, prevent, detect, and correct security violations that involve the transmission of information.

Computer Security Terminology

Attack:

- An assault or an intelligent act that is a deliberate attempt to evade security services and violate the security policy of a system.

Security Policy :

- A set of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources.

Threat:

- A potential for violation of security, which exists when there is a circumstance, capability, action, or event, that could breach security and cause harm.

Possible security violations:

- User A transmits a file to user B. The file contains sensitive information(e.g., payroll records) that is to be protected from disclosure. User C, who is not authorized to read the file, is able to monitor the transmission and capture a copy of the file during its transmission.
- D transmits a message to computer E, instructing E to update an authorization file. User F intercepts the message, alters its contents to add or delete entries and forward to E which accepts the message as being from D.
- User F constructs its own message and transmits to E as if coming from D
- Denying sending a message

Threat Consequences

Unauthorized disclosure is a threat to **confidentiality**

- **Exposure**: This can be deliberate or be the result of a human, hardware, or software error
- **Interception**: unauthorized access to data
- **Inference**: e.g., traffic analysis, use of limited access to get detailed information
- **Intrusion**: unauthorized access to sensitive data

Threat Consequences

Deception is a threat to either system or data integrity

- **Masquerade**: e.g., an attempt by an unauthorized user to gain access to a system by posing as an authorized user; Trojan horse.

- **Falsification**: altering or replacing of valid data or the introduction of false data

- **Repudiation**: denial of sending, receiving or possessing the data. Example: In online transactions, a user might deny authorizing a payment or placing an order, leading to disputes and potential financial losses for businesses.

Threat Consequences

Disruption is a threat to availability or system integrity

- **Incapacitation**: a result of physical destruction of or damage to system hardware.
- **Corruption**: system resources or services function in an unintended manner; unauthorized modification
- **Obstruction**: e.g. overload the system or interfere with communications, overload the system by placing excess burden on communication traffic or processing resources.

Threat Consequences

Usurpation is a threat to system integrity.

- **Misappropriation**: e.g., theft of service, distributed denial of service attack
- **Misuse**: security functions can be disabled or thwarted

Key Objectives of Computer Security:

- ✓ Three key objectives of computer security are:
- Confidentiality
- Integrity
- Availability
- ✓ Two additional most commonly mentioned security concepts :
- Authenticity
- Accountability

Confidentiality:

This term covers two related concepts:

Data confidentiality:

Assures that private or confidential information is not made available or disclosed to unauthorized individuals.

Privacy:

Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.

Integrity

This term covers two related concepts:

Data integrity:

Assures that information and programs are changed only in a specified and authorized manner.

System integrity:

Assures that a system performs its intended function in an unimpaired manner, free from inadvertent unauthorized manipulation of the system.

Availability

- Assures that systems work promptly and service is not denied to authorized users.

CIA Triad

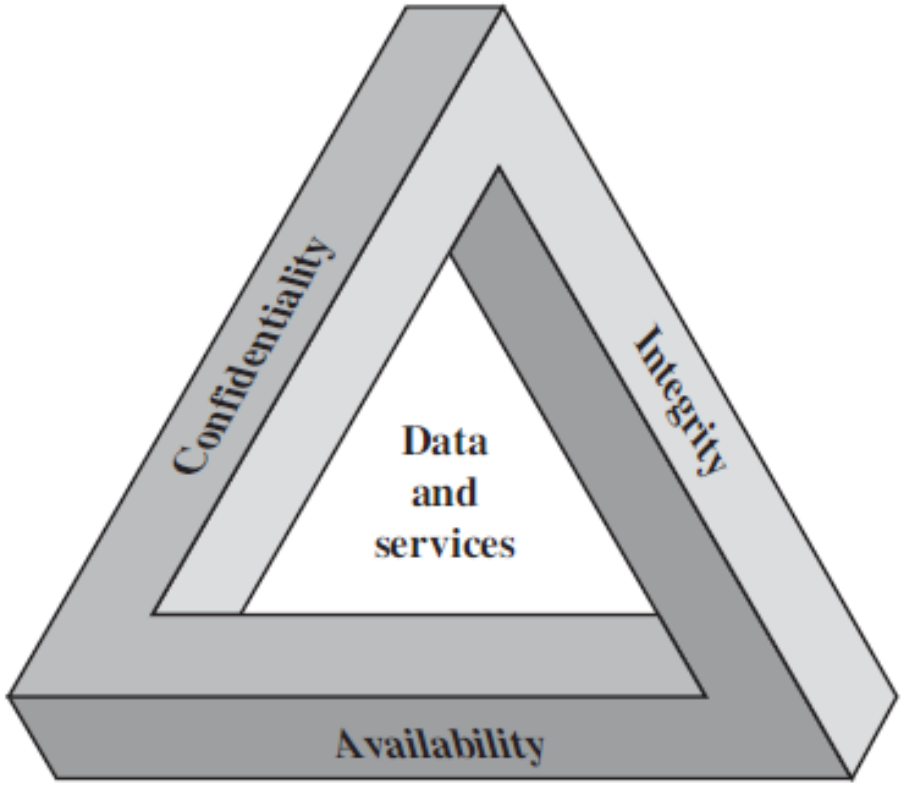


Figure 1.1 The Security Requirements Triad

Authenticity:

- The property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or message originator.
- This means verifying that users are who they say they are and that each input arriving at the system came from a trusted source.

Accountability

- The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity. This supports nonrepudiation, deterrence, fault isolation, intrusion detection and prevention, and after-action recovery and legal action.

OSI Security architecture

- ITU-T X.800 Security Architecture for OSI local copy defines a systematic way of defining and providing security requirements provides a useful, although abstract, overview of network security concepts.

- The OSI security architecture focuses on
  - **security attack**
  - **security mechanism**
  - **security service**

Security Attack

- any action that compromises the security of information owned by an organization
- information security is about how to prevent attacks, or failing that, to detect attacks on information-based systems
- have a wide range of attacks

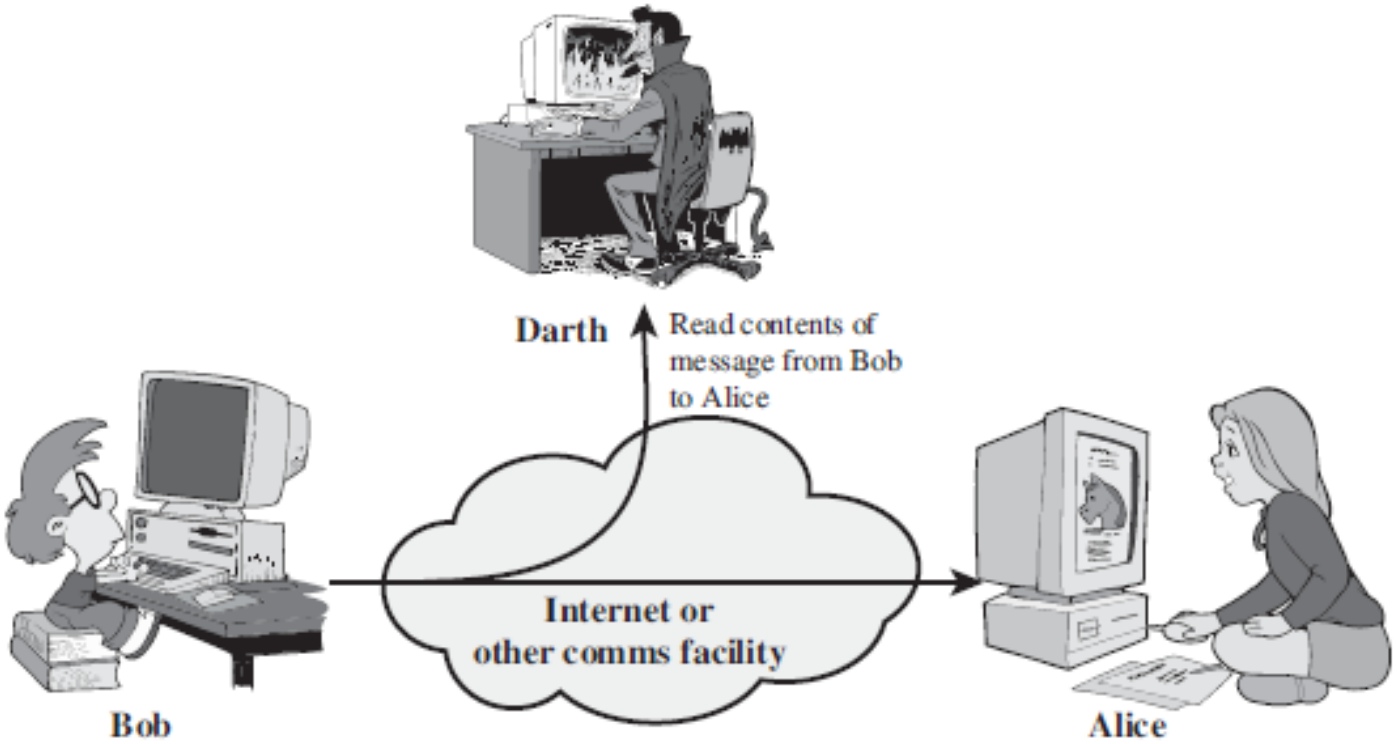
Threat Vs. Attack

- *Threat*: a circumstance or scenario with the potential to exploit a vulnerability, and cause harm to a system.
- *Attack*: A deliberate attempt to breach system security.
- note: often *threat* & *attack* mean same

Classify Security Attacks

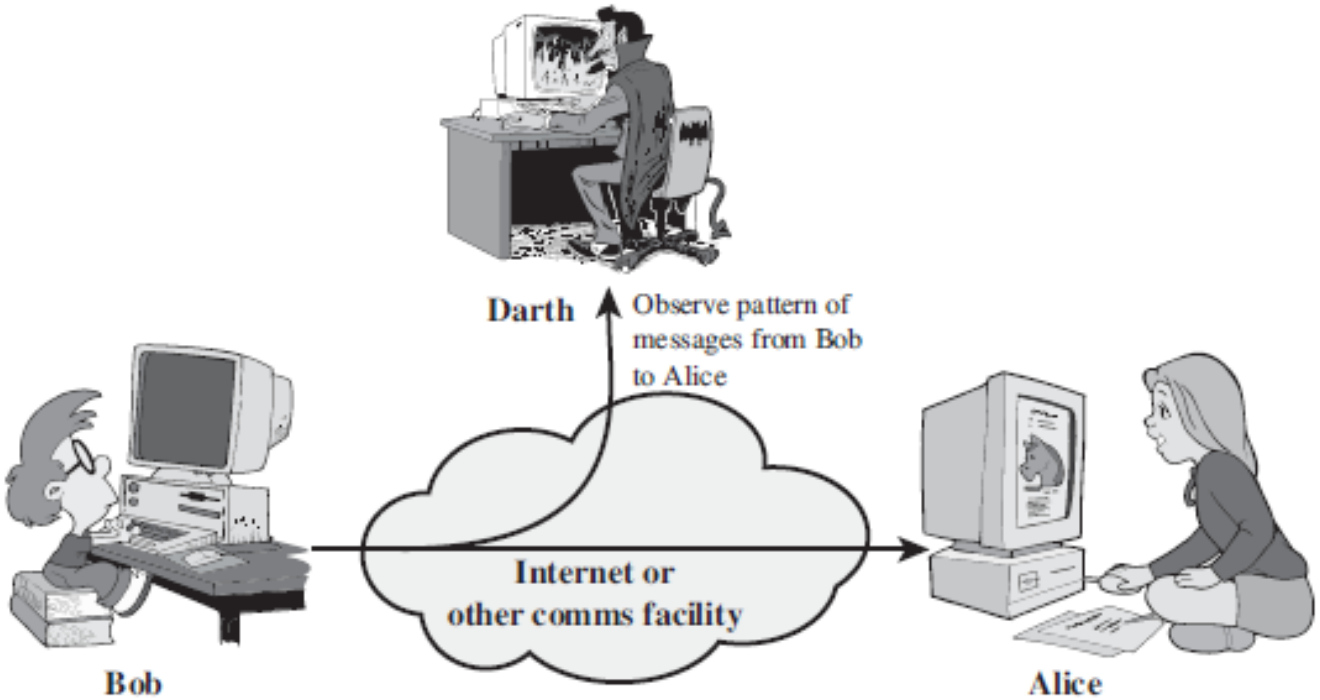
- **PASSIVE ATTACKS** –: An attempt to learn or make use of information from the system that does not affect system resources.
- eavesdropping on, or monitoring of, transmission
  - obtain message contents, or
  - monitor traffic flows
- **ACTIVE ATTACKS** –: An attempt to alter system resources or affect their operation
- modification of data stream to:
  - masquerade of one entity as some other
  - replay previous messages

Passive attack



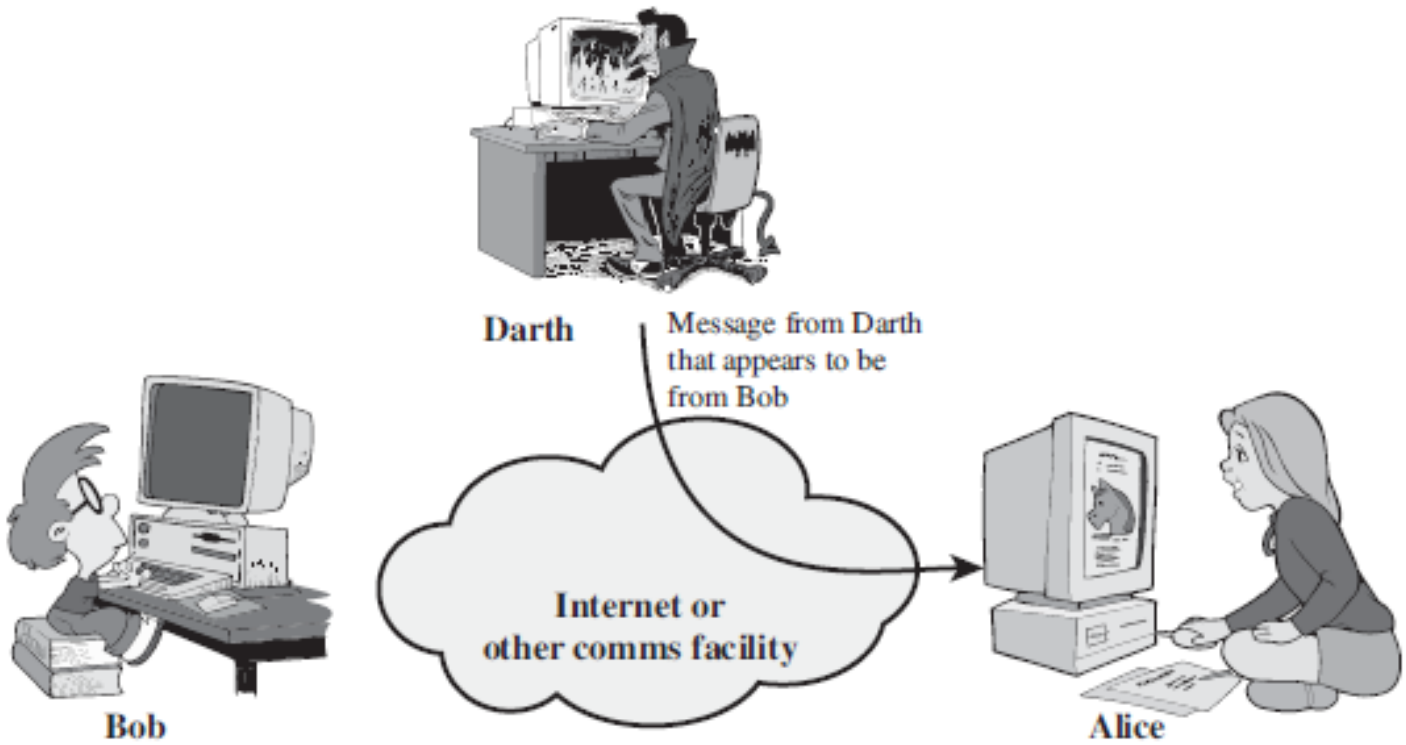
(a) Release of message contents

…



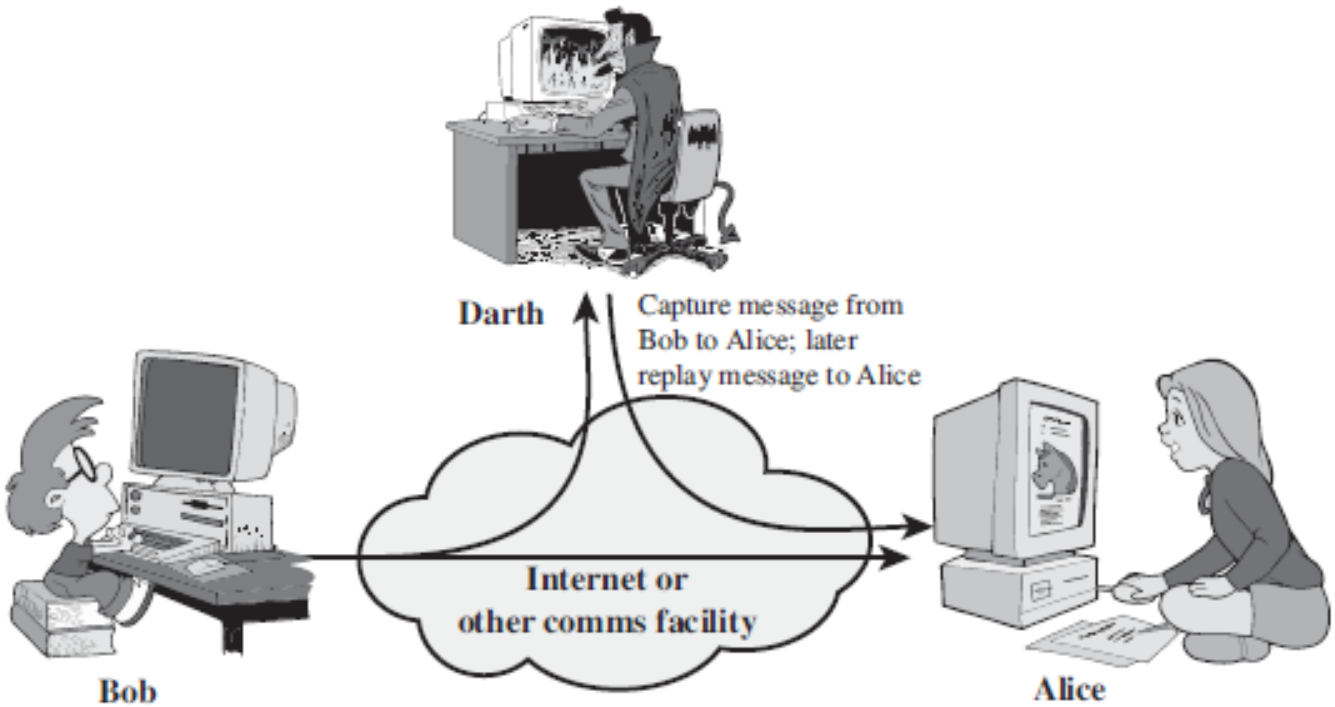
(b) Traffic analysis

Active attack



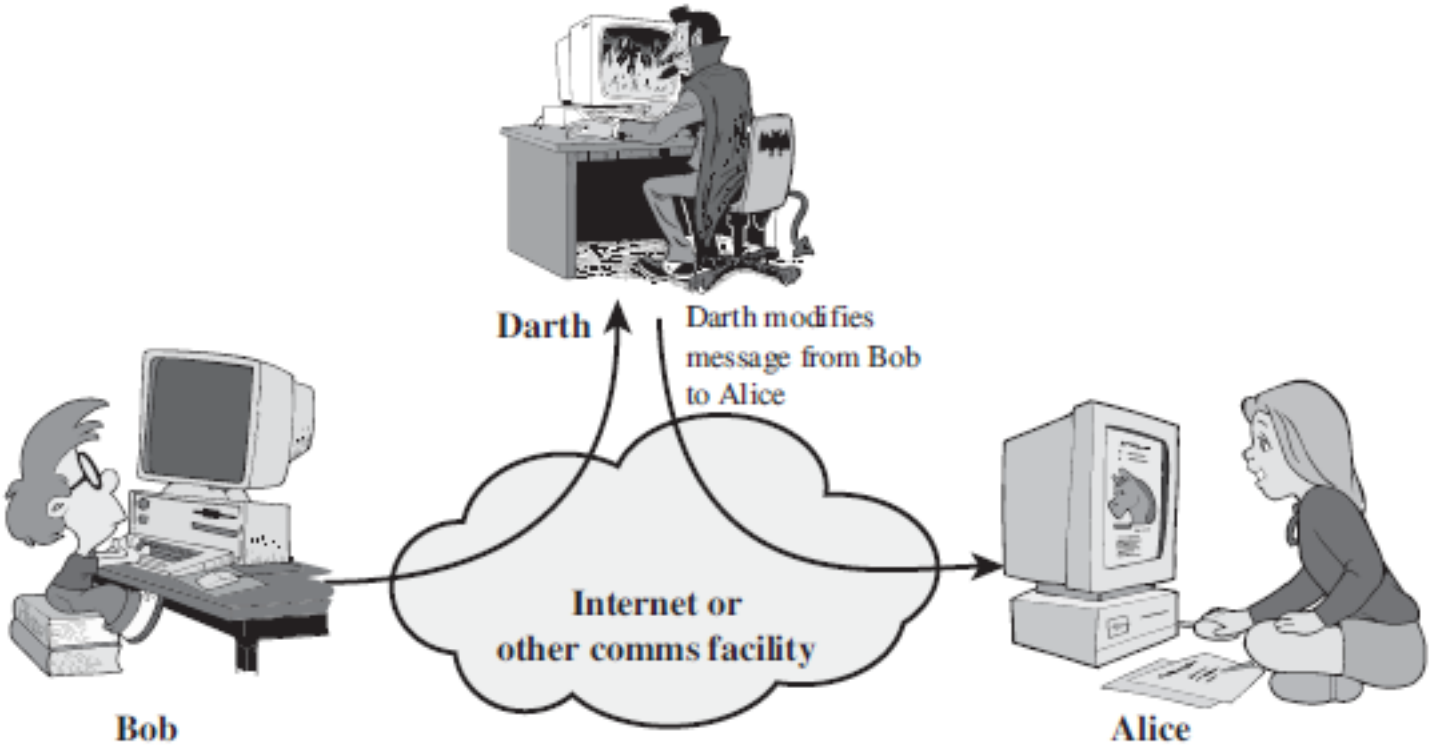
(a) Masquerade

…


Darth
Capture message from
Bob to Alice; later
replay message to Alice
Internet or
other comms facility
Bob
Alice

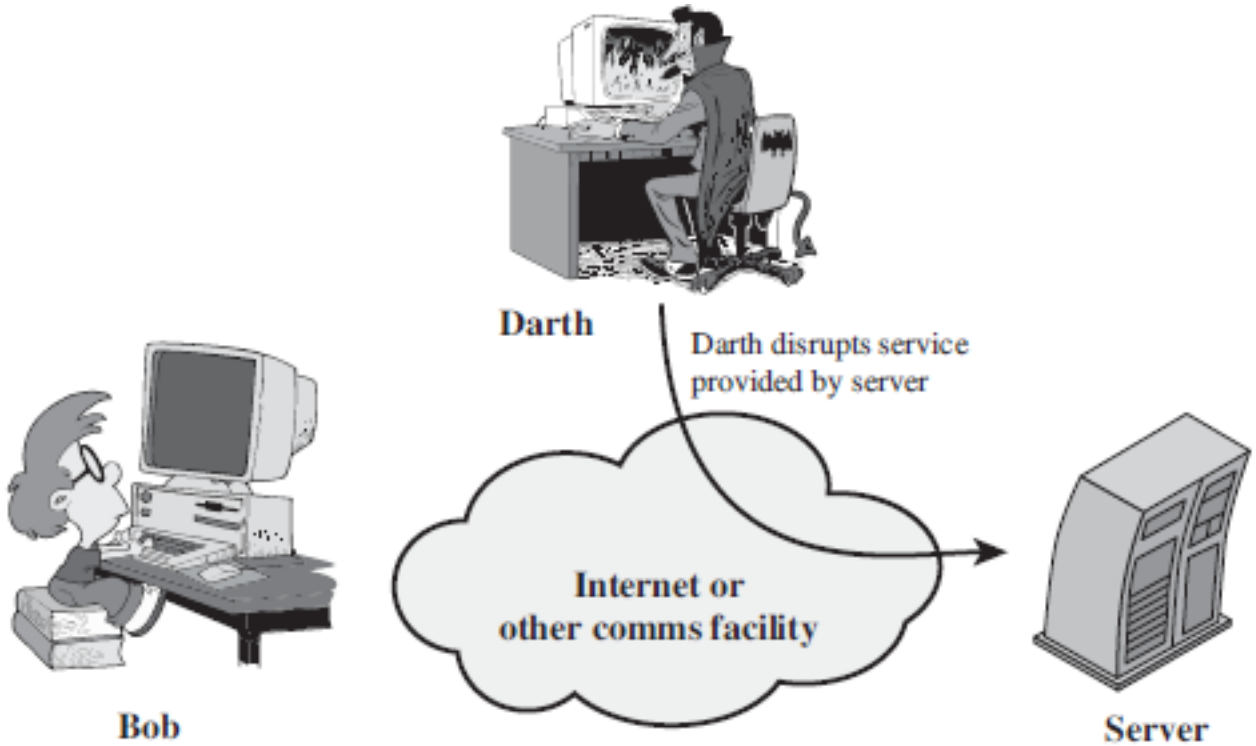
(b) Replay

…



(c) Modification of messages

…



(d) Denial of service

Security Service

- is something that enhances the security of the data processing systems and the information transfers of an organization
- intended to counter security attacks
- make use of one or more security mechanisms to provide the service
- replicate functions normally associated with physical documents
  - eg have signatures, dates; need protection from disclosure, tampering, or destruction; be notarized or witnessed; be recorded or licensed

Security Services

- X.800 defines it as:

A service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers

- RFC 2828 defines it as:

A processing or communication service provided by a system to give a specific kind of protection to system resources

- X.800 defines it in 5 major categories

Security Services (X.800)

- Authentication - assurance that the communicating entity is the one claimed
- Access Control - prevention of the unauthorized use of a resource
- Data Confidentiality –protection of data from unauthorized disclosure
- Data Integrity - assurance that data received is as sent by an authorized entity
- Non-Repudiation - protection against denial by one of the parties in a communication

Security Mechanism

- A mechanism that is designed to detect, prevent, or recover from a security attack.
- Examples of mechanisms are encryption algorithms, digital signatures, and authentication protocols.

Security Mechanisms (X.800)

- specific security mechanisms:
  - encipherment, digital signatures, access controls, data integrity, authentication exchange, traffic padding, routing control, notarization
- pervasive security mechanisms:
  - trusted functionality, security labels, event detection, security audit trails, security recovery

Security Policy

- At the least, a security policy is an informal description of desired systems behaviors.
- More usefully, a security policy is a formal statement of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources.

Factors needed to consider while developing a Security Policy

- The value of asset being protected
- The vulnerabilities of the system
- Potential threats

Computer Security Terminology

- **Adversary** (threat agent) - An entity that attacks, or is a threat to, a system.
- **Attack** - An assault on system security that derives from an intelligent threat; a deliberate attempt to evade security services and violate security policy of a system.
- **Countermeasure** - An action, device, procedure, or technique that reduces a threat, a vulnerability, or an attack by eliminating or preventing it, by minimizing the harm it can cause, or by discovering and reporting it so that corrective action can be taken.

Computer Security Terminology

- **Asset:** The organizational resource that is being protected. An asset can be logical, as a Web site, information, or data; or an asset can be physical, such as a person, computer system, or other tangible object or are the focus of security efforts
- **Exploit:** A technique used to compromise a system.

Computer Security Terminology

- **Risk** - An expectation of loss expressed as the probability that a particular threat will exploit a particular vulnerability with a particular harmful result.
- **Security Policy** - A set of rules and practices that specify how a system or org provides security services to protect sensitive and critical system resources.
- **System Resource (Asset)** - Data; a service provided by a system; a system capability; an item of system equipment; a facility that houses system operations and equipment.

Computer Security Terminology

- **Threat** - A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm.

- **Vulnerability** - Flaw or weakness in a system's design, implementation, or operation and management that could be exploited to violate the system's security policy.

CNSS Security Model

- Committee on National Security Systems (CNSS):
- CNSS document presents a comprehensive information security model and has become a widely accepted evaluation standard for the security of information systems.
- This security model is a comprehensive model of InfoSec known as the McCumbers cube created in 1991, which is named after a developer, John McCumber.
- It is becoming standard to determine the characteristics, location, and security of the information System.
- It is a three-dimension model, three dimensions are represented in a cube with 27 cells with each cell representing each aspect of information.

CNSS Security Model

- The cells that can be represented are the below:
- Confidentiality, Integrity, availability
- Policy, Education, Technology
- Storage, Processing, Transmission
- The McCumbers Cube ,three dimensions with each axis become a 3x3x3 cube with 27 cells representing areas that must be addressed to secure today's information systems.
- Each of the 27 areas must be properly addressed during the security process.

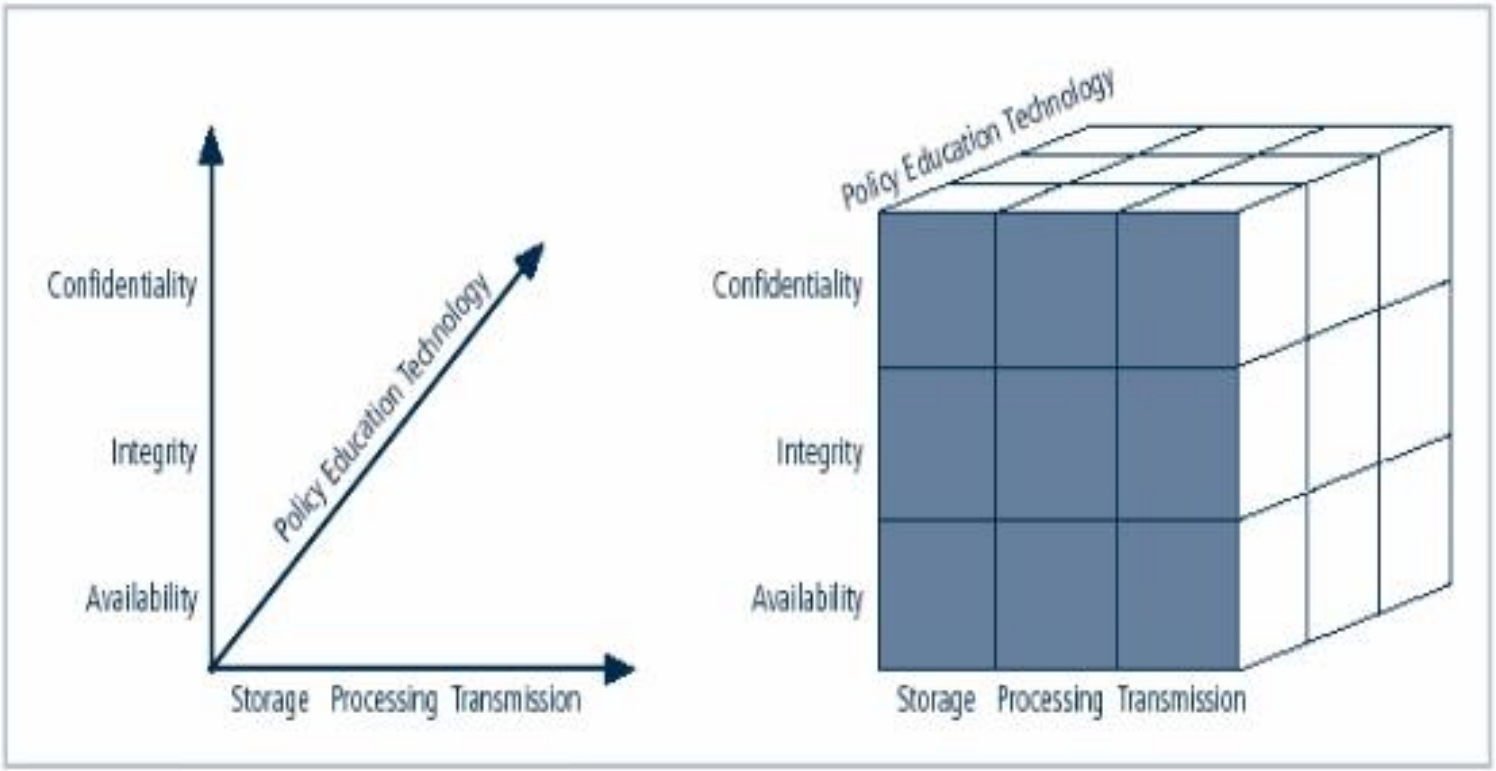


Figure 1-5 NSTISSC Security Model

CNSS Security Model

- **For example**
- The intersection between technology, integrity, and storage requires control or safeguard that addresses the need to use technology to protect the integrity of information while in storage.
- One such control might be a system for detecting host intrusion that protects the integrity of information by alerting the security administrators to the potential modification of critical files.

Component of Information System

- Information system (IS) is much more than computer hardware; It is the entire set of
  - Software
  - Hardware
  - Data
  - People
  - Procedures
  - Networks
- All of these component make possible the use of information resources in the organization.
- Each component has its own strengths and weaknesses, as well as its own characteristics and uses.
- Each component of the information system also has its own security requirements.

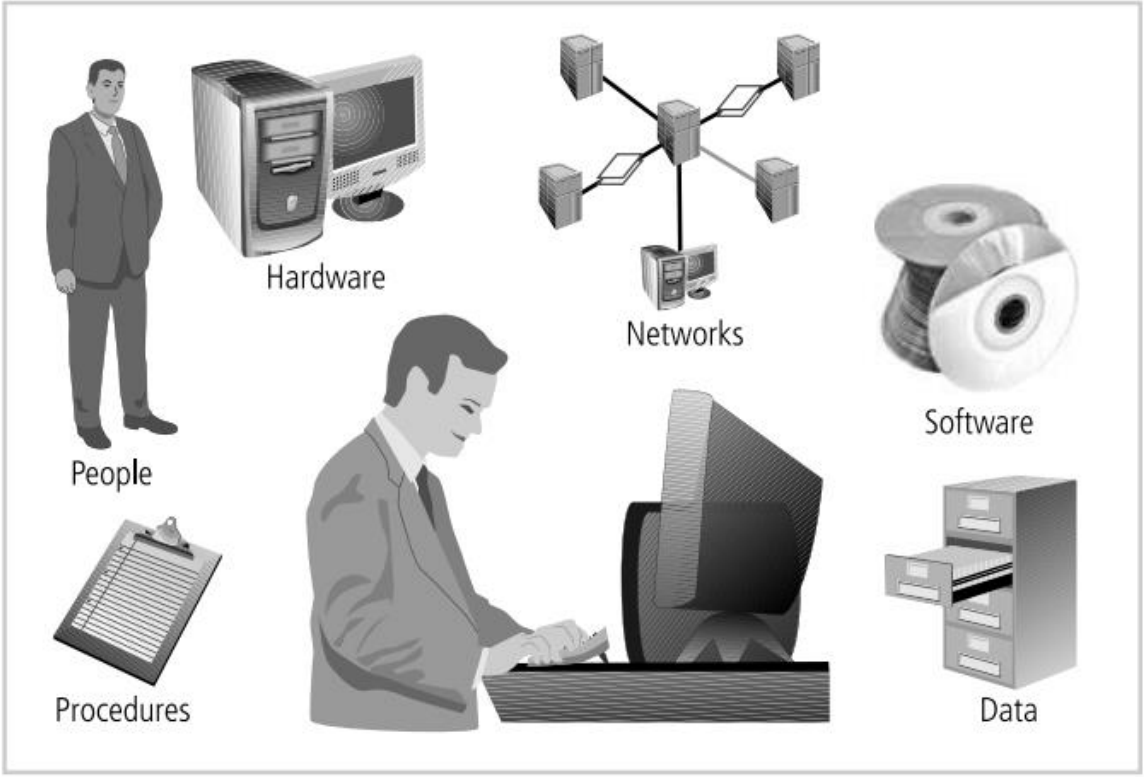


Figure 1-7 Components of an Information System

Software

- The software component of the IS comprises applications, operating systems, and assorted command utilities.
- Is difficult IS component to secure.
- Software programs are often created under the constraints of project management, which limit time, cost, and manpower.
- Information security is all too often implemented as an afterthought, rather than developed as an integral component from the beginning.
- In this way, software programs become an easy target of accidental or intentional attacks.

Hardware

- Physical technology that houses and executes the software, stores and transports the data, and provides interfaces for the entry and removal of information from the system.
- Physical security policies deal with hardware as a physical asset.
- Traditional tools of physical security, such as locks and keys, restricts access to and interaction with the hardware components of an information system.
- Securing the physical location of computers and the computers themselves is important because a breach of physical security can result in a loss of information.

Data

- Data stored, processed, and transmitted by a computer system must be protected.
- Most valuable asset possessed by an organization and it is the main target of intentional attacks.
- Database management system when done properly provide data security.

People

- People have always been a threat to information security.
- Legend has it that around 200 B.C. a great army threatened the security and stability of the Chinese empire. So ferocious were the invaders that the Chinese emperor commanded the construction of a great wall that would defend against the Hun invaders. Around 1275 A.D., Kublai Khan finally achieved what the Huns had been trying for thousands of years. Initially, the Khan's army tried to climb over, dig under, and break through the wall. In the end, the Khan simply bribed the gatekeeper—and the rest is history.

People

- Moral of the story is that people can be the weakest link in an organization's information security program.
- Unless policy, education and training, awareness, and technology are properly employed to prevent people from accidentally or intentionally damaging or losing information, they will remain the weakest link.

Procedures

- Procedures are written instructions for accomplishing a specific task.
- When an unauthorized user obtains an organization's procedures, this poses a threat to the integrity of the information.
- Most organizations distribute procedures to their legitimate employees so they can access the information system, but often fail to provide proper education on the protection of the procedures.
- Educating employees about safeguarding procedures is as important as physically securing the information system.
- After all, procedures are information in their own right. Therefore, knowledge of procedures among employees, should be a need-to-know basis.

Networks

- When information systems are connected to each other to form local area networks (LANs), and these LANs are connected to other networks such as the Internet, new security challenges emerge.
- Network security is essential, as is the implementation of alarm and intrusion systems to make system owners aware of ongoing compromises.

Balancing Information Security and Access

- To achieve balance:
- that is, to operate an information system that satisfies the user and the security professional—
- the security level must allow reasonable access, yet protect against threats.
- Ensure the data is available when, where, and how it is needed, with minimal delays or obstacles.

Balancing Information Security and Access

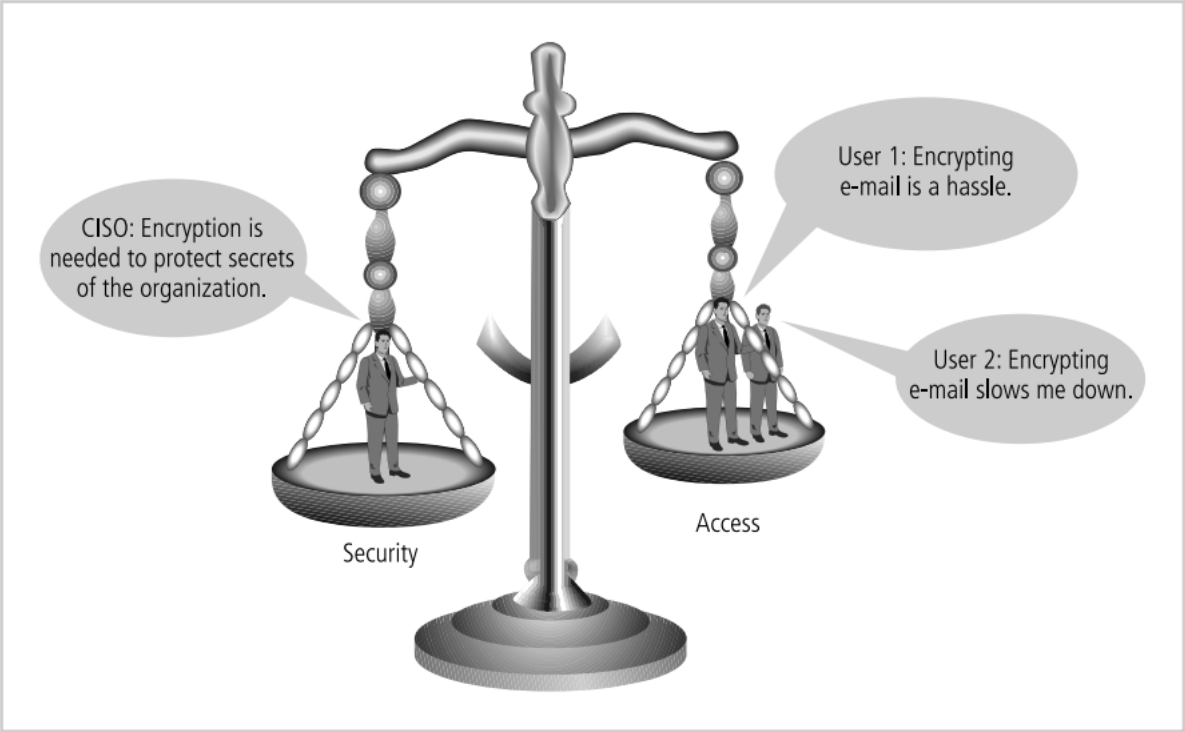


Figure 1-8 Balancing Information Security and Access

Implementation of Information security

- Bottom-up Approach
- Top Down Approach
- **Bottom-up Approach:** in which systems administrators attempt to improve the security of their systems.
- **Advantages:**
- Technical expertise of administrators
- Working with information systems on a day-to-day basis,
- in-depth knowledge that enhance the development of an information security system.
- They know and understand the threats to their systems and the mechanisms needed to protect them successfully.
- **Disadvantage:** Seldom works, as it lacks a participant support and organizational staying power.

Implementation of Information security

- Top Down Approach :
- Project is initiated by upper-level managers who issue policy, procedures and processes, dictate the goals and expected outcomes, and determine accountability for each required action—has a higher probability of success.
- This approach has strong upper-management support.

Further Readings

- Computer Security by William Stallings and Lawrie Brown
- Cryptography and Network Security by William Stalling 6th Edition, 2012

Questions